

[doc. web n. 9941205]
Provision of September 14, 2023
Register of Provisions
No. 400 of September 14, 2023

THE GUARANTOR FOR THE PROTECTION OF PERSONAL DATA

IN THE meeting today, attended by
Prof. Ginevra Cerrina Feroni, Vice President,
Dr. Agostino Ghiglia and Attorney Guido Scorza,
Members, and Dr. Claudio Filippi, Deputy
Secretary General;

HAVING REGARD TO Regulation (EU) 2016/679 of the European Parliament and of the Council, of April 27, 2016, concerning the protection of natural persons with regard to the processing of personal data, as well as the free movement of such data and repealing Directive 95/46/EC - General Data Protection Regulation (hereinafter "Regulation");

HAVING REGARD TO, in particular, Articles 35 and 36 of the Regulation relating, respectively, to the data protection impact assessment and the prior consultation of the Authority;

HAVING REGARD TO Legislative Decree No. 196 of June 30, 2003, containing the "Code regarding the protection of personal data" (hereinafter "Code");

HAVING REGARD TO, in particular, Article 110, paragraph 1, of the Code on the processing of personal data for medical, biomedical, and epidemiological research;

HAVING REGARD TO the Ethical Rules for processing for statistical or scientific research purposes adopted by the Guarantor, pursuant to Article 20, paragraph 4, of Legislative Decree No. 101 of August 10, 2018, with provision No. 515, of December 19, 2018 (doc. web n. 9069637, hereinafter "Ethical Rules");

HAVING REGARD TO the Provisions regarding the processing of personal data carried out for scientific research purposes, Annex No. 5 to the Provision that identifies the provisions contained in the General Authorizations that are compatible with the Regulation and with Legislative Decree No. 101/2018 for the adaptation of the Code, of June 5, 2019 (doc. web n. 9124510, hereinafter "Provisions");

HAVING REGARD TO the documentation on file;

HAVING REGARD TO the observations made by the Secretary General pursuant to Article 15 of the Regulation of the Guarantor No. 1/2000 on the organization and functioning of the office of the Guarantor for the protection of personal data, at www.gpdp.it, doc. web n. 1098801;

Report by Prof. Ginevra Cerrina Feroni;

PREMISE

1. The inspection and procedural activity carried out

The Office of the Guarantor, by virtue of service order No. XX of XX, conducted inspections on XX and XX pursuant to Article 58, paragraph 1, letters a), e) and f) of the Regulation and Articles 157 and 158 of the Code, as well as pursuant to Articles 21 and 22 of Regulation No. 1/2019 of the Guarantor (G.U. No. 106 of May 8, 2019), at the private institute for hospitalization and care of a scientific nature - IRCCS, MultiMedica S.p.A. (hereinafter "MultiMedica" or "Institute"), in order to verify compliance with the provisions regarding the protection of personal data, particularly in relation to the processing carried out for medical, biomedical, and epidemiological research purposes.

1.1. Verification of XX

On the day of XX, the Institute, after describing its structure and organization, stated that it conducts about one hundred annual research projects, including clinical trials, including those internal, funded by the Ministry of Health. In this regard, the Institute stated that "the responsible office that analyzes

funding calls (Grant office) supports researchers in the applications [i.e., in the] submission of the research project, or in all those activities that are of an administrative nature, budget, preparation of the necessary documentation to participate in the call;

it also assists the researcher in the project proposal. Once the project proposal has been approved by the Ministry, it becomes the recipient of the funding."

Regarding the research projects funded by the Ministry of Health, the Institute highlighted that the data management service supports researchers (study coordinators) from the moment of the project proposal, through its development, until its conclusion. In particular, it deals with the internal feasibility study and support in preparing all the documentation that must be submitted for approval to the competent Ethics Committee.

Once the favorable opinion of the Ethics Committee is obtained - which approves all the documentation of the research project: in particular, the informed consent form which may include specific authorizations directed to patients for the collection of biological samples or genetic data - the project is proposed to the patient by the doctor who collects informed consent through a paper form and transmits it to the data management office.

At this stage, the data entry staff uploads the patient data into the database representing them in two records: the first contains the personal data of the patients associated with an alphanumeric code (typically generated at the discretion of the operator from the acronym of the study, to which a progressive number is added), the second, in which all the clinical information of the patient necessary for the study is collected. This is based on the indications contained in the protocol of the study itself. The data entry staff is authorized to access all clinical data of the patient. The loading phase occurs by manually extracting from the reporting repository, through a "copy and paste" operation, only those... necessary for the study. The quality control of the data is entrusted to another data entry staff member (four eyes check). Further monitoring activities are carried out by a third staff member from the same office directly on the medical records and outpatient reports. The coding adopted for each patient is unique and persistent over time; therefore, there is effectively no distinction between historical data and prospective data. In detail, for example, in the case of a prospective study, the reporting system allows, potentially, the authorized staff member to view all reports related to the same patient, including any retrospective information that may be present but is not necessary. Specifically, at this stage, the personal data processed for research purposes can be traced back to those processed for care purposes.

In relation to the authorizations granted to employees regarding the processing of personal data they become aware of while performing their duties, the Institute has stated that "employees at the time of hiring receive the same authorization for the processing of personal data and that specific access authorization profiles to the IT systems are currently provided in relation to the different roles performed within the company," clarifying that the authorization for data processing for scientific research purposes is included in the first point of the model acquired in the records, which refers to "the protection of the health of the data subjects, namely prevention, diagnosis, care, rehabilitation."

With reference to the impact assessment required for "internal" research projects funded by the Ministry of Health pursuant to Article 110, paragraph 1 of the Code, the Company has finally declared that it has carried out impact assessments related to research projects conducted in co-ownership with the Cardiological Network; while regarding new projects, specific assessments on the risks related to the treatments under examination are ongoing.

During the aforementioned inspection, the section of the register of processing activities related to scientific research was also acquired, which reports the following information: "Name of the processing: PROJECTS; Purpose of the processing: Projects based on clinical studies and clinical research; Software and databases: diagnostic applications, treatment applications, and sharing applications, generic and specific software including cloud; Name and contact details of the co-controller (if present): Based on the study; categories of data subjects: PATIENTS; categories of data: IDENTIFYING, SO-CALLED SENSITIVE DATA (Pseudonymized); Categories of recipients to whom the data are or may be communicated: Coordinating entity, partner entity, funding entity, third

parties based on the study; Name of external processors (if present): third parties, based on the study; Third countries or international organizations to which the data may be transferred: Based on the study; Indication of guarantees adopted for international transfer (if applicable): Based on the study.”

1.2. Verification of XX

On the day of XX, access was made to the reporting system (computerized) to simulate and verify the data entry process of the data collected for care purposes and then used for research purposes. This access pertains to the prospective study named “Retinal” (hereinafter referred to as the Study), which was still ongoing at the time and also involves the collection of biological samples and genetic data that are analyzed at MultiMedica.

The data entry phase is managed by staff authorized to access the patients' medical records, upon authorization from the human resources office and verification of the functions performed by them (through the system called “ticketing”). It consists of the preparation of Excel files and documents stored within specific shared folders of the file system. In particular, the Institute has stated that in the subfolder dedicated to the “Retinal” study, there are: official documents of the Study to be submitted to the Ethics Committees, working documents, correlation tables, and the status of advancement of the Study. Once the documentation is complete, the data is transmitted to the researcher for the realization of the Study. The Study includes a preliminary enrollment phase that does not require any data analysis. It is therefore a sort of historical document archive, on which the data management staff are not required to perform any analysis activities.

In the subfolder “Study Activities,” there is an Excel file named “Enrolled Patients” where all patients who become part of the Study are recorded, after formal control of the documentation related to the “informed” consent for voluntary participation in scientific research. The Excel file contains a table that includes records of patients identified through a code that includes an acronym of the Study and a progressive number. It was possible to verify that this table also includes the following personal data: name and surname of the patient, date of birth, date of enrollment, and that these latter are classified through a “color coding” mechanism of the records. It has been specified that both the nomenclature adopted for the attributes and the choice and representation of the classes are left to the discretion of the staff member and may vary from study to study, with potential impacts on the interoperability of the data related to the same data subject when it is present in different studies, as well as on the accuracy of the classifications adopted, since these may vary from case to case. For example, with reference to the study examined, it emerged that the field “biobank” indicates that the study involves the collection and examination of biological samples. The clinical data of the patients present in the reporting system are imported from this archive into the subfolder named “webclus1/studi Clinici” designated for the collection of such information. The identification of the patient in the reporting system occurs upon entering a search key. Among the possible search keys are the personal data of the patient (name, surname, and date of birth) which the data entry staff retrieves from the paper documents containing the informed consents.

It has also emerged that at this stage it is possible to view the entire clinical history of the patient available at MultiMedica, but the staff, through a manual operation of “copy-paste” or “transcription,” acquires only the data of interest for the Study. The records in which the clinical data are entered respond to specific requests of the protocol, and it is the analyst's responsibility to ensure that there are no excess data. MultiMedica also represented that the clinical data are collected in a folder located in another common area called “studi_clinici.” In relation to the examined Study, the Institute specified that in the table containing the health data, alongside the alphanumeric identification codes of the patients, there are also their direct identifiers, as the data entry operation is carried out in the outpatient setting by a healthcare professional, in this case, an “Orthoptist.”

It has also emerged that the verification aimed at preventing the same patient from being enrolled simultaneously in multiple clinical studies is managed manually by the data entry staff. The Institute finally represented that it has initiated a project called “GDPR and security,” the details of which are described in the document acquired in the minutes of the operations carried out on the XX, (see annex 2 – functional organization chart 221122_IRCCS1.pdf).

2. Violations Alleged

Based on the elements acquired during the aforementioned inspection activity, the Office - with act of XX (prot. n. XX), which must be understood as fully referenced here - has initiated, pursuant to art. 166, paragraph 5 of the Code, with reference to the specific situations of illegality mentioned therein, a procedure for the adoption of the measures referred to in art. 58, par. 2 of the Regulation, against IRCCS - MultiMedica S.p.A, inviting it to produce to the Authority defensive writings or documents or to request to be heard by the Authority (art. 166, paragraphs 6 and 7 of the Code, as well as art. 18, paragraph 1, law no. 689 of November 24, 1981).

With the aforementioned act, the Office notified MultiMedica S.p.A., based on the elements acquired and the facts emerged following the inspection and investigative activity, as well as the subsequent evaluations of the Office, that it has been established that the processing of personal data carried out by it for research purposes in the medical, biomedical, and epidemiological fields, and in particular for the realization of the study "Retinal," has been carried out in violation of articles 5, par. 1, lett. c) and f) and par. 2, 24, 25, and 32 of the Regulation and 110 of the Code. More specifically, in relation to each of the alleged violations, the following has been noted.

2.1. Obligation of data protection by design and by default

The inspection findings concerned the processing of personal data for scientific research purposes carried out by MultiMedica, particularly for conducting research funded by the Ministry of Health, pursuant to article 12-bis of Legislative Decree No. 502 of December 30, 1992, which involves the use of health data, including genetic data.

In particular, it was verified that the processing of personal data necessary for these purposes, and in particular those of selection, collection, archiving, and pseudonymization of the data, is almost entirely entrusted to manual operations carried out by the staff. The fact that in such operations the respect for the principles applicable to the processing of personal data, and in particular those of minimization, accuracy, integrity, and confidentiality, is entirely left to the subsequent and discretionary manual intervention of the staff, through mere organizational measures - which are not, and by their nature could not be, integrated into the processing from the design stage and by default - constitutes a violation of the principle of privacy by design and by default, as per art. 25 of the Regulation.

2.2. The principle of minimization

The circumstance, already highlighted above, that the data entry staff can access the reporting system and view the entire medical documentation of the patient, including that which is not necessary for the study to be carried out, constitutes a violation of the principle of minimization referred to in art. 5, par. 1, lett. c) of the Regulation, which requires the implementation of adequate guarantees and measures so that the data controller processes "adequate, relevant, and limited" data to what is necessary for the purpose of collection.

In the case at hand, it has been established that MultiMedica has not implemented technical measures aimed, for example, at excluding access to retrospective data in prospective studies and vice versa; nor, in retrospective studies, to limit access to reports related to the observation period indicated in the protocol; nor to create a system of...

****Classification of Reports that May Exclude Access to Irrelevant Ones, While Retaining the Possibility, in Case of Justified Request, to Extend the Scope of Accessible Information for a Single Study.****

From the investigations carried out, it has also emerged that the files containing the data of patients enrolled in the "Retinal" trial, in particular the file named "DB_RETINAL_with data," not only bear a pseudonym created through the assignment of a progressive numerical code, already reported in the file named "enrolled patients," but also contain the name, surname, and date of birth of the patients, as well as some health data necessary for the Study. In this regard, although the Institute has highlighted that this arises from the fact that the data entry phase would have been carried out in an outpatient setting by a healthcare professional, in any case, the data controller has not provided any technical or organizational measures to exclude such excess, thus resulting in a violation of the aforementioned principle of minimization (art. 5, par. 1, lett. c) of the Regulation).

****2.3. Integrity and Confidentiality of Data****

The elements that emerged during the operations carried out have also led to the contestation of the violation by MultiMedica of the principle of integrity and confidentiality of data, as per art. 5, par. 1, lett. f) of the Regulation and the obligation to adopt technical and organizational measures suitable to ensure a level of security appropriate to the risk, as per art. 32 of the Regulation.

This specifically refers to:

- The absence of measures to exclude that those accessing the reporting system for scientific research purposes view the entire documented reports of the patient, including therefore that which is not necessary depending on the type of study intended to be carried out;
- The application of a coding measure that is fully intelligible and of particularly simple semantics, consisting of the mere assignment of a progressive numerical code and an acronym of the Study generated manually by the staff;
- The use of basic “copy and paste” functionalities made available by data entry applications for loading information from the reporting database to the files used for research, which are easily prone to human errors by the staff with possible consequent risks for the data subjects (for example, due to the loading of personal data into an incorrect destination file), up to the possible occurrence of personal data breaches, pursuant to art. 33 of the Regulation;
- The absence of specific authorizations and instructions for the staff processing personal data for scientific research purposes.

****2.4. Processing of Personal Data for Medical, Biomedical, or Epidemiological Research Purposes****

The inspections carried out particularly concerned the processing of personal data necessary for conducting research falling under a biomedical or health research program as provided for under article 12-bis of Legislative Decree No. 502 of December 30, 1992, and more specifically the “Retinal” project.

In this regard, it was established, by explicit declaration of the data controller, that MultiMedica has neither conducted nor published the impact assessment pursuant to art. 35 of the Regulation, in relation to the aforementioned “Retinal” study nor in relation to other studies carried out based on the same regulatory premise, in violation of art. 110, paragraph 1 of the Code.

****2.5. Principle of Accountability****

For all that has already been noted, the violation of the principle of accountability as per articles 5, par. 2 and 24 of the Regulation has also been established, as the data controller has not generally demonstrated an active conduct aimed at ensuring the effective application of the principles of personal data protection through the implementation and constant review and updating of specific and adequate measures also in relation to the particular context in which the processing operations examined take place and the related risks to the rights and freedoms of the data subjects.

****3. Defensive Memoranda****

With a note dated XX (prot. n. XX), MultiMedica submitted its defensive memoranda without requesting - in order “to avoid duplications or mere references to what is represented in the defensive writings” - to be heard in a hearing, pursuant to art. 166, paragraph 5 of the Code.

In the referenced documents, with specific reference to the allegations made by the Office in the initiation of the sanctioning procedure pursuant to art. 166, paragraph 5 of the Code, MultiMedica particularly represented the following.

In general terms, MultiMedica stated that “the management of the processing of personal data and the definition of the processes for processing personal data carried out in XX at the time of the first application of EU Regulation 2016/679 with the designation of a data protection officer, has been the subject of a specific review plan that began in the month of XX with the assumption of the current head of the Information Systems function also responsible for coordinating and managing the area of Security and Data Protection and with the identification of a new data protection officer who, during the

ongoing handover, took on the role to be able to attend the inspection assessment.”

The Institute then attached a draft contract presented by the company XX titled Proposal of Cyber Security & Privacy Support version of XX.

The document states that “MultiMedica [...], in order to improve the state of its organizational and technological measures for the protection of business information and personal data, has requested XX for support in carrying out a project activity in the field of Cyber Security and Privacy.”

[...] “The assignment of XX, within this Proposal, will be focused on assisting the Client in conducting an assessment in the field of Cyber Security & Privacy in order to evaluate the level of current measures and in the adoption of a Cyber Security & Privacy Governance Model. The assistance provided by XX will be scheduled for the period XX – XX.” The draft contract appears to be signed by the proposing consulting firm but not by MultiMedica.

The memorandum continues with a specific paragraph (n. 1) titled “With reference to the charge regarding the violation of principles related to the obligation of privacy by design, minimization, and the integrity and confidentiality of data.”

In this regard, it has been stated that “[...] the processing of personal data is actually carried out by highly qualified personnel, who, by virtue of their role, have the skills to adequately process the special categories of personal data. These individuals have always operated as authorized subjects for the processing of personal data, receiving specific instructions from the Company.”

The Company has therefore stated that “in the context of strengthening the technical and organizational measures that the company [...] had already initiated prior to the inspection assessment” [...] “an update of the authorization document for the processing of personal data has been planned, in which the purpose of scientific research has been explicitly stated.” This document has also been submitted as evidence.

With reference to the techniques of data pseudonymization, MultiMedica has declared that it has “initiated market research to identify a software tool for generating a pseudonym through a robust, non-sequential, and randomized method.”

Regarding the contestation of the violation of the principles of minimization and integrity and confidentiality of data, the Institute has stated that it has “long initiated an evaluation process that allows for the identification of a solution aimed at extracting the necessary data for research without access to personal data and/or irrelevant reporting concerning the research purpose. Currently, in the context of scientific research activities, MultiMedica uses both structured data, i.e., data present in databases organized according to rigid schemas and tables, and unstructured data, i.e., data not conforming to a data model. As for structured laboratory diagnostic data, a solution has already been successfully tested (for a scientific research project that required the extraction of laboratory analysis results) that allows for the automatic extraction of the necessary data for research purposes. It is confirmed that the extraction of structured laboratory data will occur in the future using this methodology. The adoption of more advanced tools for the extraction of unstructured data (for example, in the form of free text in reports) is also under evaluation, taking into account the state of the art, ongoing projects (particularly the digitization of the clinical record), implementation costs, and the complexity of implementation related to the variability of parameters, information, and measurements required for different research purposes.”

Paragraph n. 2 of the memorandum is dedicated to “the charge concerning the processing of personal data for medical, biomedical, or epidemiological research purposes.”

In this regard, it has been specifically stated that “[...] within the responsibilities provided for by Article 24 of EU Regulation 2016/679, the processing activities have been carried out based on the available technical solutions for their management, taking into account the number of patients enrolled for the studies conducted and the characteristics of each study. Therefore, the company, considering the activity carried out and the context itself, has implemented a modification of the EPR system, i.e., the archive of reports, which allows for managing user access based on the following criteria:

- Facility;
- Operational unit;
- Level of access to personal data differentiating the following three levels:

- 1) Level 0 complete visibility of the patient's reports;
- 2) Level 1 complete viewing, only in case of an open episode (e.g., outpatient or instrumental visit, hospitalization), of the patient's clinical history;
- 3) Level 2 viewing only of the report of the open episode.”

It has also been represented that “in the context of strengthening the technical and organizational measures for compliance with current privacy regulations, specific instructions have been defined and disseminated that require the exclusive use of the pseudonym associated with the health data obtained for research (eliminating the duplication of name, surname, and date of birth of patients).”

This document - submitted as evidence - indicates in particular that “Furthermore, the Group commits to applying the following technical measures to ensure data security and, in particular: the anonymization of personal data, where the

research purposes can be achieved through the processing of data that do not allow, or no longer allow, the identification of the data subject; the pseudonymization of data, where the purposes of scientific research can be achieved using pseudonyms. The best practices to ensure proper pseudonymization are:

- use a robust, non-sequential, and randomized pseudonymization method;
- ensure data integrity;
- document the pseudonymization process.

In the case of using Excel files in the data analysis process for scientific research purposes, the Group commits to applying a logical partitioning of the filesystems/network shares on which the various subjects involved in the research process operate: (i) the subjects who collect the data (ii) the subjects who prepare the databases containing the data subject to research, (iii) the subjects who analyze the data.

This partitioning is structured according to the following approach:

adoption of a first partition reserved for the collection of data from enrolled patients. This partition is accessible to the subjects who collect the data and to the subjects who prepare the databases containing the data subject to research;

adoption of a second partition reserved for the preparation of a correlation table between the collected data and the data subject to analysis, aimed at the creation and assignment of pseudonyms to the enrolled patients. This partition is accessible exclusively to the subjects who prepare the databases containing the data subject to research;

adoption of a third partition reserved for the analysis of pseudonymized data for research purposes. This partition is accessible to the subjects who analyze the data and to the subjects who prepare the databases containing the data subject to research.

In accordance with the principle of minimization, only the subjects who prepare the databases containing the data subject to research are authorized to have visibility over both the collected data and the data to be analyzed for research purposes. The subjects who collect the data and those who analyze them are denied any general and/or cross-sectional visibility.

That said, the Institute has stated that “Considering that the internal research studies conducted as Data Controller involve the processing of personal data of a limited number of patients, the adoption of a technical tool that allows for dynamic, parametric, and therefore personalized profiling based on the specific needs of each study is particularly complex and difficult to adopt. Therefore, the company has deemed that the implementation of such a solution represents a technical burden that is not sustainable, neither economically nor technically.

However, MultiMedica has declared that it has initiated an evaluation activity to identify a technological solution that allows for the automatic pseudonymization of patient data in addition to a more effective extraction of data, particularly unstructured data, without access to personal data and/or reporting that is not relevant to the research purpose.

Regarding the failure to execute and publish the impact assessment, which are necessary operations pursuant to Article 110 of the Code for the processing of personal data for research purposes falling within a biomedical or health research program provided for under Article 12-bis of Legislative Decree No. 502 of December 30, 1992, MultiMedica has stated that “the company, as clarified during the inspection assessment, in this specific case managed the Retinal study in compliance with the clinical

protocol and related informed consent approved by the Ethics Committee and in accordance with Good Clinical Practices.”

In any case, MultiMedica, within the framework of ongoing activities regarding the proper management of the protection of patients' personal data, as part of actions to strengthen technical and organizational measures for compliance with current privacy regulations, has declared that it has prepared the impact assessment in relation to the Retinal study, transmitting it in the records, and that “At the same time, an extensive training activity on the topic of preventive impact assessment has been carried out to ensure the systematic execution of this requirement prior to any research project in which MultiMedica is called to participate, defining a plan for identifying the activities subject to impact assessment and carrying them out.

Regarding the contestation of the violation of the accountability principle referred to in Articles 5, paragraph 2, and 24 of the Regulation, the Institute has declared that “[...] the Data Controller since XX had equipped the organization with a team of internal staff and external collaborators, at the time identified and tasked with defining the correct procedures for managing personal data and documenting such compliance. This process, which was managed until XX, was strongly conditioned during the period XX by the need to manage the health emergency that made the orderly management of such activity particularly difficult. Once the emergency was overcome in the second half of XX, the Data Controller found the need to review and improve the approach taken to its personal data management model through the definition of an activity plan and the assignment of the same to a new working group. The prepared plan [...] therefore involved the hiring of a figure with expertise. specificities in the organizational and management field and in the consequent replacement of the data protection officer; the inspection took place at a time when the consolidation project had just begun and indeed continued in the following weeks, precisely with the awareness that it is the duty of the Data Controller to adequately document the management of personal data. MultiMedica is committed to completing this process in a short time.”

In relation to the alleged violations, MultiMedica, for the assessments of the Office pursuant to Article 83 of the Regulation, declared:

to have “carried out the processing within the scope of its activity based on the clinical protocol and related informed consent approved by the Ethics Committee. No cases related to complaints from data subjects have occurred, in protection of the rights of the data subjects”;

that “the number of subjects involved in the study ‘Retinal’ has so far concerned 53 patients”;

to have acted in good faith “in its role as a participant in a research activity according to criteria defined by the entities promoting such research and that it was deemed appropriate to use data in the context of the activities;

“the company had established, well before the inspection assessment, a plan for consolidating the processes of managing personal data. In this context, clarifying that no actual damage has been determined for the data subjects, the company has extended the scope of the instructions given to the authorized subjects for processing within the research, has conducted a specific impact assessment related to the study ‘Retinal’ and has carried out an adequate training program aimed at defining the conduct of impact assessments of personal data processing in the future”;

to have “defined an intervention plan for a systematic review of all procedures for processing personal data. In this context, it has defined the periodic verification of the adequacy of the processing processes carried out. In light of the observations that emerged during the inspection assessments, processes for data extraction for conducting research have been defined that can minimize the data processed, access to data based on the conduct of the research, and actions are underway to improve the processes of pseudonymization and anonymization in order to better protect the data subjects”;

that “the [...] company has provided with total transparency and collaboration to the supervisory authority all the information in its possession and has responsibly initiated, well before the inspection assessment, a path of renewal of its data management procedures”;

to have proceeded with the hiring “in XX of a professional figure who deals with this issue and the designation, formalized during the inspection, of a new data protection officer to replace the one previously designated on XX”;

to have already implemented some corrective measures regarding the alleged violations;
to have never made notifications of violations pursuant to Article 33 of the Regulation “having an ongoing activity plan for the management of data processing”;
that “participation in the research does not involve specific economic benefits from the treatments subject to the alleged violations”;
to have ensured full cooperation with the Authority throughout the procedure, both during the inspection and the investigation;

The Company has finally renewed the request to the “supervisory authority to take into account the fact that the inspection occurred at a time when the process of reviewing and consolidating the procedures aimed at protecting personal data was being initiated,” trusting that “this Authority will consider this context when evaluating the reported violations, taking into particular account the collaborative approach and the planning already defined by the company, well before the inspection, for the interventions that the Data Controller, within its responsibilities, deemed appropriate to define.”

4. Applicable Legislation

The processing of personal data must take place in compliance with the Regulation and the Code. For “personal data” is meant “any information relating to an identified or identifiable natural person (‘data subject’).”

Furthermore, “a natural person is considered identifiable who can be identified, directly or indirectly, particularly by reference to an identifier such as a name, an identification number, location data, an online identifier, or to one or more factors specific to the physical, physiological, genetic, mental, economic, cultural, or social identity of that natural person” (Article 4, paragraph 1, no. 1 of the Regulation).

Pseudonymization is defined as: “the processing of personal data in such a way that the personal data can no longer be attributed to a specific data subject without the use of additional information, provided that such additional information is kept separately and subject to technical and organizational measures intended to ensure that the personal data are not attributed to an identified or identifiable natural person” (Recital 26 and Article 4 point 5). Pseudonymization constitutes a measure of extreme relevance in the research sector, particularly in order to ensure effective application of the principle of minimization (Article 5, paragraph 1, letter c) and 89 of the Regulation). In this regard, the Article 29 Working Party has highlighted the implementation. This obligation requires the data controller to implement appropriate technical and organizational measures to ensure a level of security appropriate to the risk, taking into account the state of the art and the costs of implementation.

In summary, the data controller must ensure that personal data is processed in a manner that guarantees adequate security, including protection against unauthorized or unlawful processing and against accidental loss, destruction, or damage. This includes the obligation to implement appropriate technical and organizational measures to ensure a level of security appropriate to the risk, considering the state of the art and the costs of implementation.

The principle of data minimization is particularly relevant in the context of scientific research, as it requires data controllers to process “adequate, relevant, and limited data to what is necessary for the purposes for which they are processed” (Articles 5, paragraph 1, letter d) of the Regulation). In light of this principle, the data controller must not only select the information that is actually necessary for the purpose of collection but also conduct an assessment on the possibility of processing information that has been pseudonymized in advance to minimize the use, and therefore the exposure to risk, of directly identifiable information of the data subjects.

Finally, within the framework of the relevant principles in the case at hand, the principle of integrity and confidentiality of data is significant, according to which data must be “processed in a manner that ensures an adequate level of security for personal data, including protection against unauthorized or unlawful processing and against accidental loss, destruction, or damage,” which is linked to the obligation for the data controller to implement appropriate technical and organizational measures to ensure a level of security appropriate to the risk, taking into account the state of the art and the costs

of implementation.

****Implementation, as well as the nature, object, context, and purposes of the processing, as well as the risk of varying probability and severity for the rights and freedoms of natural persons (Articles 5, paragraph 2, letter f) and 32 of the Regulation).****

The Regulation then introduces the obligation for data controllers to carry out a prior impact assessment when the processing "specifically involves the use of new technologies, considering the nature, object, context, and purposes of the processing, which may present a high risk to the rights and freedoms of natural persons" (Article 35), consulting the Supervisory Authority if the technical and organizational measures identified by them to mitigate the impact of the processing on the rights and freedoms of the data subjects are deemed insufficient, that is, when the residual risk for the rights and freedoms of the data subjects remains high (Article 36). In this regard, the Guidelines concerning the impact assessment on data protection as well as the criteria for determining whether a processing "may present a high risk" under Regulation 2016/679 - WP248rev.01, adopted on April 4, 2017, as amended and last adopted on October 4, 2017, are noted. In this context, the Article 29 Working Party indicates in particular when an impact assessment is mandatory, who should conduct it (the controller, assisted by the data protection officer, if designated), what it should consist of (providing some examples based on schemes already tested in certain sectors), and the necessity to interpret it as a process subject to continuous review rather than as a one-time compliance.

Finally, with specific reference to the examined cases, Article 110 of the Code states that in the field of medical, biomedical, and epidemiological research, "1. The consent of the data subject for the processing of health-related data for scientific research purposes in the medical, biomedical, or epidemiological field is not necessary when the research is carried out based on provisions of law or regulation or Union law in accordance with Article 9, paragraph 2, letter j), of the Regulation, including the case where the research falls within a biomedical or health research program provided for under Article 12-bis of Legislative Decree No. 502 of December 30, 1992, and an impact assessment is conducted and made public in accordance with Articles 35 and 36 of the Regulation" (see also the cited Guidelines on impact assessment on data protection).

It is therefore highlighted that the legal basis for the processing of personal data (including genetic and health data) necessary for the realization of research projects that fall within a biomedical or health research program provided for under Article 12-bis of Legislative Decree No. 502 of December 30, 1992, can be found in the aforementioned sector regulations, together with two specific obligations provided for by the Code:

- i. the carrying out of an impact assessment by the data controller - which in this case must therefore be considered mandatory regardless of the assessments on the riskiness of the processing carried out by the controller in light of Article 35 of the Regulation and the aforementioned guidelines -;
- ii. the publication of the same.

If the legal basis is identified in the consent of the data subjects, even in reference to research funded under Legislative Decree No. 502 of 1992, it is understood that it must be given through a positive act by which the data subject expresses a free, specific, informed, and unequivocal will regarding the processing of personal data concerning them (Recitals 32, 42, and 43, Articles 5, 6, paragraph 1, letter a) and 7 of the Regulation and Guidelines 5/2020 on consent under Regulation (EU) 2016/679, adopted by the European Data Protection Board on May 4, 2020).

With specific reference to the special categories of data, such consent, taking into account the nature of such data, particularly sensitive from the perspective of fundamental rights and freedoms, must not only be explicit but also expressed in writing (Article 9, paragraph 2, letter a) of the Regulation and paragraph 4 of the cited Guidelines 5/2020 on consent and Article 7, paragraph 2, letter b) of the Ethical Rules for processing for statistical or scientific research purposes published pursuant to Article 20, paragraph 4, of Legislative Decree No. 101 of August 10, 2018, of December 19, 2018, Annex A5 to the Code (doc. web no. 9069637).

In this context, the European Data Protection Board has clarified in relation to clinical trials that "the

informed consent required by the regulation on clinical trials should not be confused with consent as a legal basis for the processing of personal data under the General Data Protection Regulation. The provisions of Chapter V of the regulation on clinical trials relating to informed consent, particularly Article 28, primarily respond to the fundamental ethical requirements of research projects involving human beings arising from the Declaration of Helsinki. The obligation to obtain informed consent from participants in a clinical trial is primarily a measure that ensures the protection of the right to human dignity and the right to the integrity of the person as provided for in Articles 1 and 3 of the Charter of Fundamental Rights of the European Union; it is not designed to meet data protection obligations. Under the General Data Protection Regulation, consent to processing must be given freely and must be specific, informed, and unequivocal, and, in relation to special categories of data such as health data, it must be explicit" (see points 15, 16, and 17 of Opinion 3/2019 regarding questions and answers).

****On the interaction between the clinical trial regulation and the general data protection regulation (Article 70, paragraph 1, letter b), Adopted on January 23, 2019).****

In this regard, it is emphasized that in cases where health data is collected directly from the subjects and thus involves their direct enrollment in the research project, the principle of voluntary participation in the research remains intact, in accordance with the applicable norms and ethical standards, including those of international law relevant to the sector in question (1). It is worth reiterating that the European Data Protection Board concerning clinical trials has clarified that "the informed consent required by the clinical trial regulation should not be confused with consent as a legal basis for the processing of personal data under the general data protection regulation. The provisions of Chapter V of the clinical trial regulation relating to informed consent, particularly Article 28, primarily address the fundamental ethical requirements of research projects involving human beings derived from the Helsinki Declaration. The obligation to obtain informed consent from participants in a clinical trial is primarily a measure that ensures the protection of the right to human dignity and the right to personal integrity as set forth in Articles 1 and 3 of the Charter of Fundamental Rights of the European Union; it is not designed to meet data protection obligations. Under the general data protection regulation, consent for processing must be given freely and must be specific, informed, and unambiguous, and, in relation to special categories of data such as health data, it must be explicit" (cf. points 15, 16, and 17 of Opinion 3/2019 regarding questions and answers on the interaction between the clinical trial regulation and the general data protection regulation (Article 70, paragraph 1, letter b), Adopted on January 23, 2019).

****5. The outcome of the investigative activity: the established violations****

As stated above, the Office has contested that MultiMedica's processing of personal data for research purposes in the medical, biomedical, and epidemiological fields, and in particular for the implementation of research projects funded under Article 12-bis of Legislative Decree No. 502 of 1992, such as the "Retinal" study which was specifically examined during the aforementioned inspections, was carried out in violation of Articles 5, paragraph 1, letters c) and f) and paragraphs 2, 24, 25, and 32 of the Regulation and Article 110 of the Code.

In general terms, MultiMedica illustrated, during the inspections, the document (later acquired for the record of the proceedings) titled "PROPOSAL FOR CYBER SECURITY & PRIVACY SUPPORT," as evidence of its commitment to review and improve its level of compliance with personal data protection provisions. In this regard, while favorably acknowledging the initiative, it must be noted that what was submitted constitutes a mere proposal for a contract put forward by a consulting company, not yet signed by the data controller, making it unclear whether and for how long it has been accepted, whether it has begun to produce its effects, and whether the review of internal processes has started and to what extent.

****5.1. On the principle of accountability and the obligation of privacy by design****

The Office noted that the processing of personal data carried out by MultiMedica, particularly necessary for research funded by the Ministry of Health, under Article 12-bis of Legislative Decree No.

502 of December 30, 1992, and specifically those related to the selection, collection, storage, and pseudonymization of data, is generally carried out in violation of the principle of accountability and, as it is almost entirely reliant on manual operations performed by staff (cf. point 2.1.), in violation of the principle of privacy by design and by default as per Article 25 of the Regulation.

MultiMedica attributed the violation of the accountability principle, which is the responsibility of the data controller to comply with applicable processing principles and to be able to demonstrate compliance by showing the technical and organizational measures deemed appropriate for this purpose, to the exceptional context caused by the pandemic emergency from Sars-Cov 2, which, as a healthcare institution, particularly involved it.

In this regard, while acknowledging the undeniable relevance that must be recognized to the pandemic emergency in the assessment of the responsibilities attributable to the data controller, the Authority believes that the total absence of specific measures regarding the processing under examination during the inspections is such that it cannot allow for overcoming the issue.

From the documents for providing instructions to the data subjects, to the manner of appointing the data protection officer hastily formalized during the inspection, to the superficial knowledge of the specific provisions concerning the processing of personal data for scientific research purposes in the medical field, identified during the inspection, despite the specific vocation of the entity, the absence of that proactive and responsible conduct that the accountability principle imposes on data controllers (Article 5, paragraph 2 of the Regulation) emerges.

In no case, moreover, has the Institute been able to provide justifications regarding its conduct that were not exclusively assertive, without...

must ensure that the implementation of such automated measures is accompanied by appropriate safeguards and controls to maintain compliance with data protection regulations.

5.3 On the principles of data minimization and integrity and confidentiality of data

Regarding the ineffectiveness of the pseudonymization measures in use (which, as mentioned above, accompany the pseudonym with the directly identifying data of the patient), as a tool to ensure the effective application of the principle of data minimization, we take note of the commitment made by the data controller to "identify a software tool for the generation of a pseudonym through a robust, non-sequential, and randomized method." However, the objection raised (see above point 3) is confirmed, as the data controller has not provided any defense that would allow for the overcoming of this critical issue.

With respect to the objection regarding the violation of the principles of data minimization and integrity and confidentiality of data, we take note of the Institute's intention to implement a system for the automatic extraction of unstructured data according to a methodology (not described in the documents) already tested for so-called "structured" data and to be tested for unstructured data, thus overcoming the mode deemed obsolete and inadequate, from the perspective of data integrity and confidentiality, which involved a manual "copy and paste" procedure.

In this regard, it is highlighted that, in abstract terms, the introduction of an automatic measure for data extraction can represent a valid method for preventing human errors by staff, which could potentially expose data subjects to processing that falls outside the scope of the study (for example, due to the loading of data into an incorrect destination file) and thus ensure greater effectiveness of the principle of confidentiality and integrity of data. This is subject to the necessity that the data controller ensures that the implementation of such measures is accompanied by appropriate safeguards and controls to maintain compliance with data protection regulations.

the medical, biomedical, or epidemiological field must ensure compliance with the necessary legal obligations.

5.1 Evaluation of the Effectiveness of the Chosen Measure

Despite the proposed measure, it appears that the possibility for the data extractor to view information present in the Institute's reporting system remains unchanged, which is clearly irrelevant to the

research purpose pursued, such as information related to a time frame not considered in the research project and, therefore, in the case of prospective studies, information regarding the entire clinical history of the patient.

In light of the above, acknowledging the intention of the data controller to implement automatic measures for the future extraction from the repository of health data reports related to enrolled patients necessary for the realization of specific clinical studies, while noting the critical issues highlighted above that the data controller must duly consider, given the risk exposure determined by the current manual "copy and paste" operation, a violation of the principles of minimization and integrity and confidentiality as per Article 5, paragraph 1, letter f) of the Regulation has been established; this also takes into account the inadequacy of the pseudonymization techniques observed during the inspection.

5.3 Processing of Personal Data for Research Purposes in the Medical, Biomedical, or Epidemiological Field

Regarding the violation of the necessary obligations for conducting research in the medical, biomedical, and epidemiological fields for purposes falling under a biomedical or health research program as provided for by Article 12-bis of Legislative Decree No. 502 of December 30, 1992, MultiMedica has stated that it has modified the archive of reports, strengthened technical and organizational measures, and disseminated a new document for the use of pseudonyms in scientific research.

In this regard, it is reiterated that the training and provision of new and more accurate instructions, while important and necessary, cannot be considered alternative measures to the specific obligations required of the data controller under Article 110 of the Code.

From another perspective, the data controller has stated that "Considering that the internal research studies conducted as the Data Controller involve the processing of personal data of a limited number of patients, the adoption of a technical tool that allows for dynamic, parametric, and thus personalized profiling based on the specific needs of each study is particularly complex and difficult to implement. Therefore, the company has deemed that the implementation of such a solution represents a technical burden that is not sustainable, either economically or technically."

On this point, it is noted that, given that MultiMedica is an IRCCS (Scientific Institute for Research, Hospitalization, and Health Care), the total number of subjects enrolled in approximately 100 annual research projects must be considered significant, as this activity constitutes one of the main commitments of the entity according to the explicit declaration of the data controller.

In any case, in disregard of the principle of accountability, it seems approximate to indicate a priori that the effort required for the implementation of a measure that has not yet been concretely identified, except in relation to the desired effect, is disproportionate. Furthermore, there is a lack of qualitative and quantitative assessments supporting such an abstract and generic indication of "disproportionate effort."

With specific reference to the failure to execute and publish the impact assessment pursuant to Article 110 of the Code, respect for informed consent and Good Clinical Practices has been invoked.

The Company subsequently transmitted, along with its defense documents, the impact assessment related to the Retinal study, which had not yet been conducted at the time of the inspection.

From the documentation, it emerged that the Retinal study is a prospective study that involved the enrollment of patients who presented "at the Ophthalmology Unit of San Giuseppe Hospital within two months" from the approval of the protocol and who met the inclusion criteria.

MultiMedica also submitted a copy of the form titled "informed consent" and the informed consent form and consent for data processing (privacy) related to this study. However, this documentation appears inadequate to allow for the free expression of informed consent for the processing of personal data that is distinct and autonomous from voluntary participation in the research. This is not so much

because the two consents are collected within the same form, a choice that cannot be questioned a priori, but because the information, from the perspective of data protection, lacks many of the elements required under Article 13 of the Regulation.

The information sheet, despite its name, appears entirely unbalanced in favor of consent to participate in the research compared to that related to the processing of personal data; the latter is indeed generic, lacking, and erroneous, particularly regarding the substantial difficulty for the data subject to understand the autonomous and distinct expressions of will.

On the other hand, the data controller refers in its response to [...] "the informed consent approved by the ethics committee," without specifying to which expression of will this consent refers.

In light of the above, with reference to the contested issue, it is useful to preliminarily highlight that, due to the principle of the alternative nature of legal bases, the data controller intending to process data for scientific research purposes in the medical, biomedical, or epidemiological field must ensure compliance with the necessary legal obligations.

****Medical, Biomedical, and Epidemiological Field for Purposes of****

****Research Programs in Biomedical or Health Research as Provided for by Article 12-bis of Legislative Decree No. 502 of December 30, 1992****

Where materially and ethically possible, as in the case of prospective studies (see point 5.3 of the prescriptions), it is appropriate to evaluate whether, in the specific case, the legal basis should be the consent of the data subjects or, given that it is a project provided for by the aforementioned Legislative Decree No. 502 of 1992, to proceed with the conduct and publication of the impact assessment pursuant to Article 110, paragraph 1 of the Code.

In practice, with reference to the research project in question, it is evident that the data controller has not obtained valid consent for the processing of personal data from the patients enrolled in the Study, with the consequence that since the processing is related to the conduct of a research project funded pursuant to Article 12-bis of Legislative Decree No. 502 of 1992, the data controller should have not only conducted but also published the impact assessment pursuant to Article 110, paragraph 1 of the Code.

While acknowledging that following the inspection activity the impact assessment has nonetheless been carried out, albeit not published, the violation of Article 110, paragraph 1 of the Code is therefore established.

****6. Conclusions****

In light of the evaluations mentioned above, taking into account the statements made by the data controller during the investigation – for the truthfulness of which they may be held accountable pursuant to Article 168 of the Code – the elements provided by the data controller in the defense memorandum, although deserving of consideration, do not allow for overcoming a large part of the observations notified by the Office with the initiation of the procedure, nor do any of the cases provided for by Article 11 of the Garante Regulation No. 1/2019 apply.

For these reasons, the illegality of the processing of personal data carried out by the Scientific Hospital and Care Institute, MultiMedica S.p.A., is noted, as it was carried out in violation of Articles 5, paragraph 1, letters c) and f), and paragraph 2, 24, 25, and 32 of the Regulation and Article 110 of the Code. The violation of the aforementioned provisions also makes the administrative sanction provided for by Article 83, paragraphs 4 and 5 of the Regulation applicable, pursuant to Articles 58, paragraph 2, letter i), and 83, paragraph 3, of the same Regulation.

Article 58, paragraph 2, of the Regulation provides the Garante with a series of corrective powers, of a prescriptive and sanctioning nature, to be exercised in the event that an unlawful processing of personal data is established.

Among these powers, Article 58, paragraph 2, letter d) of the Regulation provides the power to "order the data controller or the data processor to bring the processing into compliance with the provisions of this regulation, if necessary, in a specific manner and within a specified period."

****7. Corrective Measures****

In light of the evaluations mentioned above, it is deemed necessary to order the Company, pursuant to

the aforementioned Article 58, paragraph 2, letter d) of the Regulation, to bring the processing into compliance with the provisions of the Regulation within 120 days from the notification of this measure. In particular, MultiMedica S.p.A. is ordered to:

- a) identify the IT tool for generating a solid, non-sequential, and randomized alphanumeric code for effective pseudonymization of the data processed for research purposes;
- b) identify the technical measures to ensure that the activities of collecting personal data through the reporting system, archiving, and pseudonymization of data for scientific research purposes are not solely reliant on manual interventions distributed by authorized personnel and comply with the principles of data minimization and integrity and confidentiality;
- c) identify the technical measures taken for the automatic extraction of structured data and the measures intended to be taken for the automatic extraction of unstructured data;
- d) identify the technical measures to ensure that, by default, authorized personnel cannot view excessive and irrelevant information, such as that related to a time period or clinical areas not subject to the specific Study intended to be conducted (for example, access control measures, log collection, or the use of anti-data leak tools suitable to prevent patient data from being used for purposes other than research);
- e) publish on its website, even if only in excerpt, the impact assessment related to the "Retinal" study.

****8. Adoption of the Order for the Application of the Administrative Monetary Sanction and Accessory Sanctions (Articles 58, paragraph 2, letters i and 83 of the Regulation; Article 166, paragraph 7, of the Code).****

The violation of Articles 5, paragraph 1, letters c) and f), and paragraph 2, 24, 25, and 32 of the Regulation and Article 110 of the Code committed by MultiMedica is subject to the application of the administrative monetary sanction, pursuant to Article 83, paragraph 4, letters a) and 5, letters a) and b) of the Regulation.

The Garante, pursuant to Articles 58, paragraph 2, letter i) and 83 of the Regulation, as well as Article 166 of the Code, has the power to "impose an administrative monetary sanction pursuant to Article 83, in addition to [other] [corrective] measures of which...

In the present paragraph, or in lieu of such measures, depending on the circumstances of each individual case, "the Board [of the Guarantor] adopts the injunction order, which also provides for the application of the accessory administrative sanction of its publication, in whole or in part, on the Guarantor's website pursuant to Article 166, paragraph 7, of the Code" (Article 16, paragraph 1, of the Guarantor's Regulation No. 1/2019).

The aforementioned monetary administrative sanction imposed, depending on the circumstances of each individual case, must be determined in amount taking into account the principles of effectiveness, proportionality, and deterrence, as indicated in Article 83, paragraph 1, of the Regulation, in light of the elements provided in Article 83, paragraph 2 of the Regulation. In this regard, it is noted that:

- the processing carried out particularly involved information capable of revealing health status and genetic data related to patients enrolled in the Retinal study, vulnerable subjects (Article 4, paragraph 1, nos. 13 and 15 of the Regulation and Article 83, paragraph 2, letters a) and g) of the Regulation);
- from the perspective concerning the subjective element, no intentional attitude emerges on the part of the data controller, as the established violations occurred in good faith (Article 83, paragraph 2, letter b) of the Regulation);
- a warning measure was adopted against MultiMedica for violation of Article 5, paragraph 1, letter f) of the Regulation (Article 83, paragraph 2, letter e) of the Regulation) (provision of June 18, 2020, doc. web 9451705);
- MultiMedica has adopted various measures to comply, already during the investigation phase, with the applicable regulations;
- MultiMedica has demonstrated cooperation during the inspection and investigation phases;
- as a Hospital and Scientific Care Institute, MultiMedica was particularly affected by the emergency caused by the Sars-Cov 2 pandemic, which emerged only two years after the full entry into force of the Regulation.

In light of the aforementioned elements, assessed as a whole, it is deemed appropriate to determine the amount of the monetary sanction provided for in Article 83, paragraph 5, of the Regulation, in the amount of €80,000 (eighty thousand) for the violation of Articles 5, paragraph 1, letters c) and f) and paragraph 2, 24, 25, and 32 of the Regulation and 110 of the Code as an administrative monetary sanction deemed, pursuant to Article 83, paragraphs 1 and 3, of the Regulation, effective, proportionate, and deterrent.

It is also considered that the accessory sanction of publication on the Guarantor's website of this provision, as provided for in Article 166, paragraph 7 of the Code and Article 16 of the Guarantor's Regulation No. 1/2019, should be applied, also considering the type of personal data subject to unlawful processing.

Finally, it is noted that the conditions referred to in Article 17 of Regulation No. 1/2019 concerning internal procedures with external relevance, aimed at carrying out the tasks and exercising the powers assigned to the Guarantor, are met.

ALL OF THE ABOVE, THE GUARANTOR declares the unlawfulness of the processing of personal data carried out by the Scientific Hospital and Care Institute (IRCCS) MultiMedica S.p.A., tax code/VAT number 06781690968, with registered office at Via Fantoli Gaudenzo 16/15, Milan, for the violation of Articles 5, paragraph 1, letters c) and f) and paragraph 2, 24, 25, and 32 of the Regulation and 110 of the Code as stated in the reasoning.

ORDERS

pursuant to Articles 58, paragraph 2, letter i) and 83 of the Regulation, as well as Article 166 of the Code, that the company MultiMedica pay the sum of €80,000 (eighty thousand) as an administrative monetary sanction for the violations indicated in this provision. It is represented that the offender, pursuant to Article 166, paragraph 8, of the Code, has the option to settle the dispute by paying, within 30 days, an amount equal to half of the imposed sanction.

ORDERS

the company MultiMedica:

1. to pay the sum of €80,000 (eighty thousand) - in case of failure to settle the dispute pursuant to Article 166, paragraph 8, of the Code - according to the methods indicated in the annex, within 30 days from the notification of this provision, under penalty of the adoption of the consequent executive acts pursuant to Article 27 of Law No. 689/1981;
 2. pursuant to Article 58, paragraph 2, letter d) of the Regulation, to bring the processing into compliance with the provisions of the Regulation, adopting the corrective measures indicated in paragraph 7 of this provision, no later than 120 days from the notification of this provision, taking care to:
 - a) identify the IT tool for generating a solid, non-sequential, and randomized alphanumeric code for effective pseudonymization of the data processed for research purposes;
 - b) identify the technical measures to ensure that the activities of collecting personal data through the reporting system, archiving, and pseudonymization of data for scientific research purposes are not solely entrusted to manual interventions distributed by authorized persons and comply with the principles of minimization and integrity and confidentiality of data;
 - c) identify the technical measures taken for the automatic extraction of structured data and the measures intended to be taken for the automatic extraction of unstructured data;
 - d) identify technical measures in order to exclude by default that authorized persons may view excessive and irrelevant information, such as that related to a time period or clinical areas not subject to the specific Study intended to be conducted (by way of example, access control measures, log collection, or the use of anti-data leak tools suitable to prevent patient data from being used for purposes other than research);
 - e) publish on its website, even if only in excerpt, the impact assessment related to the "Retinal" study.
 3. pursuant to Article 58, paragraph 1, letter a), of the Regulation and Article 157 of the Code, to
- Failure to comply with an order issued pursuant to Article 58, paragraph 2, of the Regulation is punishable by the administrative sanction referred to in Article 83, paragraph 6, of the Regulation;

communicate what initiatives have been undertaken in order to implement the provisions set forth in the aforementioned paragraph 7, and to provide feedback, adequately documented, no later than 20 days from the expiration of the above-mentioned deadline. Failure to respond to a request made pursuant to Article 157 of the Code is punishable by the administrative sanction, pursuant to the combined provisions of Articles 83, paragraph 5, of the Regulation and 166 of the Code.

ORDERS

pursuant to Article 166, paragraph 7 of the Code, the full publication of this provision on the website of the Authority and considers that the conditions set forth in Article 17 of Regulation No. 1/2019 concerning internal procedures of external relevance, aimed at carrying out the tasks and exercising the powers entrusted to the Authority, are met.

Pursuant to Article 78 of the Regulation, Articles 152 of the Code, and Article 10 of Legislative Decree No. 150/2011, against this provision it is possible to appeal to the ordinary judicial authority, under penalty of inadmissibility, within thirty days from the date of communication of the provision itself or within sixty days if the appellant resides abroad.

Rome, September 14, 2023

THE VICE PRESIDENT

Cerrina Feroni

THE REPORTER

Cerrina Feroni

THE DEPUTY SECRETARY GENERAL

Filippi

1) Declaration of Helsinki of the World Medical Association (WMA), containing ethical principles for biomedical research involving humans adopted in June 1964 and subsequent amendments; the Convention on Human Rights and Biomedicine, adopted by the Council of Europe in Oviedo on April 4, 1997, and the Additional Protocol concerning biomedical research of 2005; the Universal Declaration on the Human Genome and Human Rights, adopted by UNESCO on November 11, 1997; the International Declaration on Human Genetic Data of UNESCO of October 16, 2003.